CYBERSECURITY USER STUDY ORIENTATION

Insider Threat Detection User Study

Investigating deep learning behavioral anomaly detection and Explainable AI (XAI) dashboard architectures across security operations workflows.

Bi-LSTM Autoencoder | CERT r5.2 Dataset | SHAP Explainability | Design A vs. Design B

The Core Security Challenge: Legitimate Access

Insider threats originate from individuals with authenticated privileges, complicating conventional perimeter defense.

Why Detection is Hard

- **Legitimate Authorized Access:**
  Insiders routinely log in, query databases, send emails, and use storage drives as part of regular work duties.
- **Innocent Single Actions:**
  An isolated file access, USB attachment, or off-hours login is often completely legitimate business activity.
- **Subtle Behavioral Shift:**
  Threats emerge through deviations in behavioral sequence, timing anomalies, and combinations of actions over time.
- **Human Context Required:**
  Machine alerts highlight unusual deviation, but security analysts must evaluate contextual intent.

Evaluated Telemetry Streams

- **Logon / Logoff Events:**
  Authentication timestamps, workstation machine IDs, off-hours session durations, and weekend activity.
- **HTTP Web Traffic:**
  External browsing, search engine queries, job board visits, and cloud storage/wikileaks upload attempts.
- **Email Metadata:**
  Internal communications, external personal webmail destinations, competitor solicitations, and attachments.
- **File System Interactions:**
  Directory navigation, sensitive file reads, archive staging, and keylogger transfers.
- **Removable Device Operations:**
  USB thumb drive insertions, file copying volumes, and rapid unmount sequences.

DETECTION PARADIGMS

Comparing Threat Detection Methodologies

Traditional and machine-learning approaches exhibit distinct operational trade-offs.

Rule-Based Approaches

Predefined Indicators

Mechanism:
Matches actions against predefined static rules and known regex signatures.

Strength:
Highly reliable for known threat patterns and zero-tolerance policy violations.

Limitation:
Brittle against novel evasion tactics, modified sequences, or zero-day behavior.

Statistical Profiling

Metric Outliers

Mechanism:
Establishes historical baseline averages and flags statistical standard deviations.

Strength:
Catches sudden volume spikes in activity (e.g., mass file copies or bandwidth surges).

Limitation:
Cannot interpret if a volume surge is malicious exfiltration or legitimate project crunch.

Traditional ML

Feature Correlator

Mechanism:
Supervised models (Random Forest, SVM) learning relationships between features.

Strength:
Detects non-linear multivariate correlations across diverse telemetry streams.

Limitation:
Treats actions as isolated static snapshots, largely ignoring multi-step temporal sequence.

Deep Learning

Bi-LSTM Autoencoders

Mechanism:
Bidirectional recurrent autoencoders modeling sequence and temporal transitions.

Strength:
Learns user's normal sequential baseline over time without rigid rules.

Requirement:
Flags behavioral anomalies; requires human SOC analyst security interpretation.

PART 2 - MODEL ARCHITECTURE

Detection Approach: Bi-LSTM Autoencoder

Neural network behavioral anomaly detection evaluated against the CERT r5.2 insider threat benchmark.

1. Temporal Event Sequences

Modeling Activity Chains

• User actions occur as sequences over time (Logon → Browse → File Access → USB Insertion → Email → Logoff).

• The Bidirectional Long Short-Term Memory (Bi-LSTM) network captures complex temporal patterns across forward and backward contexts.

• Prevents relying on isolated independent events, capturing multi-step behavioral workflows.

2. Learned Normal Baselines

Reconstruction Error

• The Autoencoder trains on an employee's 90-day normal baseline activity window to compress and reconstruct normal work.

• When subsequent daily activities deviate from established patterns, reconstruction accuracy drops.

• Inaccurate reconstruction produces an elevated Anomaly Score representing behavioral divergence.

3. Bayesian Thresholding

Operational Alert Generation

• Bayesian optimization establishes an optimal Anomaly Cutoff Threshold to minimize false discovery rates.

• Days exceeding the threshold line are flagged automatically for human security analyst inspection.

• Enables baseline deviation monitoring without writing predefined rules for every threat variation.

CORE TRIAGE PRINCIPLE

An Anomaly is Not Automatically an Insider Threat

The most foundational principle for every analyst in this study.

A High Anomaly Score Indicates:

✔ Statistical deviation from the learned 90-day baseline work pattern.

✔ Unusual timing, sequence, or volume of workstation interactions.

✔ A triage alert warranting human investigation, evidence correlation, and context review.

It Does NOT Indicate:

✘ Mathematical probability that an employee is malicious or disloyal.

✘ Definitive proof of data theft, sabotage, or policy violation.

✘ An automated verdict that replaces security judgment and evidence correlation.

OPERATIONAL REALITY: Employees behave differently for legitimate reasons (e.g., project deadlines, new assignments, shifting work hours, or sudden workload crunches). The analyst must correlate context before concluding malicious intent.

PART 3 - INVESTIGATION FRAMEWORK

The Analyst's Role & Three Guiding Questions

The system flags where investigation is needed; the analyst must determine what occurred.

Question 1

Baseline Deviation

"What behavior made this activity unusual relative to the learned baseline?"

Identify whether the alert was driven by unusual off-hours login times, abnormal web upload volumes, foreign device connections, or irregular email recipients.

Question 2

Behavioral Context

"Does the surrounding evidence show a meaningful security-related pattern?"

Correlate related actions across multiple audit files to discover if individual events connect into an intentional attack chain (e.g., job search → thumb drive → competitor email).

Question 3

Totality of Evidence

"Considered together, does evidence support a threat or non-threatening work?"

Examine whether observed spikes are better explained as legitimate business activity (overtime sprint, IT scripts) or intentional exfiltration/sabotage.

ANALYST TRIAGE PROTOCOL

Four Core Triage Rules & Evidence Threshold

Systematic investigative rules to distinguish operational workload shifts from insider threats.

Rule 1: Temporal Schedule

👉 **Check the Clock**

Compare activity timestamps against user's regular schedule (Mon–Fri, 8:00 AM–6:00 PM). Off-hours and weekend logins represent critical anomaly signals.

Rule 2: Multi-Telemetry

👉 **Connect the Pieces**

Never convict on a single clue. A USB or file access may be routine work; examine the entire chain across web, file, email, and device logs.

Rule 3: Intent Disambiguation

👉 **Unusual ≠ Malicious**

High reconstruction error reflects routine deviation, not malice. Distinguish approved overtime crunches or role changes from intentional data theft.

Rule 4: Evidence Threshold

👉 **The 1 + 2 Formula**

Strict Rule: Must find exactly 1 Primary Indicator + at least 2 Secondary Indicators before assigning any threat scenario (S1–S6).

📋 Triage Reminder: Do not make decisions from the anomaly score alone, nor from a single feature, SHAP bar, or scenario indicator. Correlate raw logs and temporal sequence.

TRIAGE REFERENCE GUIDE

Scenario Checklist Rubric (S1–S6)

Standardized threat signatures, indicators, and triage principles from the SOC Dashboard reference guide.

⚡ **Triage Principle: Indicators = Starting Signals (1 Primary + 2 Secondary) | Logs/Features = Supporting Evidence | Verdict = Deep Digging Across Baseline**

Scenario ID	Scenario Description	Primary Indicator	Secondary Indicators	Supporting Evidence
S1 - IP Theft via Media	User with no prior removable drive or after-hours activity starts logging in after hours, using a removable drive, and uploading data to wikileaks.org, then leaves shortly after.	**Wikileaks Access**	Thumb Drive, After-Hours	Correlate unusual timing, removable-media behavior, web activity, prior baseline & departure context.
S2 - Fraud via Job/USB	User searches job websites and solicits competitor employment. Before leaving, they heavily use a thumb drive to steal data, exceeding prior activity levels.	**Job Site Access**	Competitor Email, Thumb Drive	Compare removable-drive activity against historical baseline and correlate with departure behavior.
S3 - Misuse via Keylogger	Disgruntled administrator downloads a keylogger, transfers it via thumb drive to supervisor's machine, uses keylogs to send mass email causing panic, then leaves.	**Keylogger Download**	Unauthorized Login, Mass Email	Reconstruct multi-step sequence: device, malware/keylogger, supervisor machine access, mass email & timing.
S4 - Exfiltration	User logs into another user's machine, searches for files, and emails them to a personal account, with increasing frequency over 3 months.	**Unauthorized Login**	File Search, Home Email	Examine cross-user machine access, file activity, personal email destination & longitudinal 3-month increase.
S5 - Mixed Profile	Multi-Vector Overlapping Activity Profile matching complex scenario combinations or data blending variations.	**Overlapping Spikes**	Multi-vector indicators	Correlate multi-vector overlapping spikes across multiple telemetry channels.
S6 - Benign Anomaly	High statistical deviation triggered by legitimate workload spikes or task shifts without malicious intent or exfiltration activity.	**Isolated Deviation**	Safe task spikes	Documented task shift/workload spikes; no malicious exfiltration indicators.

Design A: Conventional Triage Workspace

Standard SOC analytical telemetry: statistical timelines, historical distributions, raw audit logs, and case assessment.

Core Interface Modules

- **Date-wise Anomaly Timeline:**
  Interactive timeline plotting daily reconstruction error scores against the Bayesian anomaly cutoff line.
- **Detected Anomalies Table:**
  Summary table listing all flagged alert dates with severity metrics, deviation headroom, and disposition selectors.
- **Day-Level Z-Score Toggle:**
  Inspection toggle displaying standardized reconstruction error Z-scores relative to normal baseline variance.
- **Autoencoder Feature Inspector:**
  Categorized behavioral features (logon, HTTP, email, file, device) showing audited vs. baseline averages.
- **Scenario Checklist & Guide:**
  Sidebar reference guide with defined threat scenarios S1 through S6, indicators, and triage principles.

Telemetry & Case Assessment

- **Raw User Actions Log:**
  Filterable, searchable chronological audit trail of individual events (logon, web, email, file, device).
- **Action Badges & Indicators:**
  Inline alert tags highlighting suspicious activity (e.g., job-site browsing, external webmail, keyloggers).
- **Day-Level Dispositions:**
  Dropdown controls to record operational verdicts (True Threat vs. Dismiss Alarm) and scenario per date.
- **Case Closure Assessment:**
  Final decision section to enter Overall Classification, confidence rating, investigation notes, and analyst ID.
- **Evidence Package Export:**
  Generates an auditable JSON session dossier for verification after all flagged dates are dispositioned.

INTERACTIVE TRIAGE WALKTHROUGH

Where to Click in Design A

Step-by-step navigation through the conventional analyst workflow.

Step 1: Inspect Timeline

Select Flagged Day

Review anomaly spikes crossing the threshold. Click a flagged date in the table to synchronize all panels to that date's features and logs.

Step 2: Toggle Z-Scores

Evaluate Deviations

Toggle 'Show Reconstruction Error Z-scores' to see how many standard deviations the daily error deviates from baseline normal.

Step 3: Correlate Logs

Filter Raw Actions

Expand 'Raw User Actions', filter by activity type, and search for indicators: external domains (wikileaks, jobs), USB mounts, or email targets.

Step 4: Record Assessment

Export Dossier

Select Day Disposition & Scenario for every flagged date. In Case Assessment, select Overall Classification, Confidence, and Export Evidence.

EXPERIMENTAL CONDITION

Design B: Explainable AI (XAI) Suite

Identical baseline capabilities enriched with complementary local and global SHAP attributions.

SHAP Waterfall Plot

Local Attribution (Selected Day)

- Explains model output for a single selected observation or flagged date.
- Shows directional push/pull: red bars increase the anomaly score; blue bars decrease it toward normal baseline.
- Identifies exactly which behavioral features drove the anomaly spike on that specific day.

SHAP Beeswarm Plot

Global Attribution (Monitoring Period)

- Provides a global macro summary across the entire post-90-day monitoring period.
- Shows feature impact distributions across all analyzed test observations.
- Reveals which behavioral dimensions chronically trigger risk vs. routine baseline stability.

🤖 Interactive AI Assistant Scope & Guardrails

Available to explain plot mechanics and feature terminology. Strict Guardrail: The assistant does NOT decide malice, select threat scenarios, or replace human analytical judgment.

INTERACTIVE XAI WALKTHROUGH

Where to Click in Design B

Step-by-step navigation through the explainability suite and interactive features.

Step 1: Global Context

SHAP Beeswarm Map

Click the Beeswarm thumbnail card to view global feature distributions across the full monitoring window. Understand macro feature importance.

Step 2: Day Attributions

SHAP Waterfall Plot

Select any flagged date to load its specific SHAP Waterfall plot. View which features pushed the anomaly score above the cutoff line.

Step 3: Lightbox Tools

Zoom, Pan & Metrics

Click any plot thumbnail to open high-resolution Lightbox modal with zoom controls, pan navigation, and automated mathematical metric summaries.

Step 4: AI Clarification

Ask the Assistant

Select a plot and ask the AI assistant for clarification on plot terminology or feature influence direction (investigative aid only).

COMPARATIVE ARCHITECTURE

Side-by-Side: Design A vs. Design B

Comparing interface capabilities across both study conditions.

Design A: Conventional

Baseline Condition

- Date-wise Anomaly Score Timeline with Cutoff
- Feature-level and day-level Z-score deviation stats
- Autoencoder input features (daily telemetry averages)
- Searchable chronological Raw User Actions log
- Scenario Checklist & Guide (S1–S6 signatures)
- Day-level dispositions and overall case closure assessment

Design B: XAI Suite

Explainability Condition

- All Design A core investigation capabilities included
- SHAP Beeswarm Plot (global monitoring distribution across window)
- SHAP Waterfall Plot (local per-day feature attributions)
- High-resolution Lightbox modal with zoom, pan & metric summary
- Interactive AI Assistant for plot mechanics & feature clarification

Study Purpose: Examine whether an explainability-enhanced dashboard affects investigation accuracy, triage efficiency, confidence calibration, and analyst cognitive workload.

PART 5 - STUDY PROTOCOL

Study Protocol & Training User 162

Controlled evaluation assessing analyst triage efficiency, accuracy, and confidence across conditions.

🎯 **User 162 Training Alerts Demonstrated: October 13, 2010 and October 26, 2010 (Guided walkthrough in both Design A and Design B)**

Evaluation Workflow

- **Guided Training (User 162):**
  Inspect two example alerts (Oct 13 & Oct 26) in Design A, then revisit the same dates in Design B to focus on XAI differences.
- **Four Study Scenarios:**
  Each participant investigates 4 unique assigned user scenarios (2 using Design A, 2 using Design B). User order is counterbalanced.
- **Mandatory Date Coverage:**
  Investigate every flagged date and assign an operational disposition and scenario (S1–S6) before exporting.
- **Overall Case Assessment:**
  Submit a single final Case Closure Classification, confidence score, rationale, and study reflections.

Critical Study Guardrails

- **No Automation Bias:**
  There is no preferred design. Do NOT try to reproduce or rubber-stamp model scores; arrive at your own independent evidence-based verdict.
- **Strict Non-Transfer Rule:**
  Dates, behavioral patterns, and conclusions from training User 162 apply strictly to the tutorial. Do NOT transfer them to study cases.
- **Placeholder Alarms in Training:**
  Remaining flagged dates in User 162 are marked 'Dismiss Alarm' solely as demonstration placeholders to show export workflow.
- **Single Case Closure Verdict:**
  The Overall Case Closure Classification is one conclusion for the entire user case, not a separate verdict for each day.